

DDTA - Scheda di lettura compilata

SRC-0004 - van Lamsweerde (2004) - Intentional anti-models

Identita bibliografica

Campo	Valore
Titolo	Elaborating Security Requirements by Construction of Intentional Anti-Models
Autore	Axel van Lamsweerde
Sede	ICSE 2004, pagine 148-157
DOI	10.1109/ICSE.2004.1317437
PDF	Autore; 10 pagine; testo e figure leggibili
SHA-256	a344418a784c8830dfd82a4b578554c8102c9702f33e15ff8ead2f35597c69da
Tipo	Metodo costruttivo, formale opzionale, quattro casi anti-model

Risultato centrale

Il metodo e pre-codice e puo partire da asserzioni dichiarative in interviste e documenti, ma richiede la costruzione di un primal model strutturato. L'anti-model e una controparte metodologica ostile, non una sostituzione della rappresentazione iniziale.

Sei meta-requisiti

Meta-requisito	Significato
Early deployment	Asserzioni dichiarative, non state machine complete
Incrementality	Ragionamento su modelli parziali
Alternatives	Minacce e contromisure alternative esplicite
High assurance	Analisi formale quando necessaria
Security-by-construction	Elaborazione guidata dei requisiti
Separation of concerns	Sicurezza distinta per analisi delle interazioni

Dualita dei modelli

Primal model	Anti-model
Goal e security goal	Anti-goal e malicious obstacle
Agent software/ambiente	Attacker e attackee
Object e asset sensibile	Oggetto monitorato o controllato
Requirement / expectation	Anti-requirement / vulnerability
Operation	Attacker capability

SRC-0004 - Input e metodo anti-model

Contratto di input

Input	Necessita
Goal e security goal	Richiesti o costruiti
Agent e responsabilita	Richiesti
Object e sensitive information	Richiesti
Operation	Richieste per operationalization
Domain properties	Richieste per regressione formale
Assumptions e NFR	Richiesti per selezione alternative
Codice	Non richiesto

Sei passi

Passo	Procedura
1	Negare security-goal pattern istanziati su oggetti sensibili
2	Chiedere WHO puo beneficiare e identificare attacker
3	Chiedere WHY e ricostruire motivazioni e anti-goal superiori
4	AND/OR-refinement fino ad anti-requirement o vulnerability
5	Derivare anti-agent, anti-object, boundary e monitor/control interface
6	Operationalizzare anti-requirement come attacker capability

Semantica delle foglie

Foglia	Criterio
Anti-requirement	Condizioni monitorabili e controllabili dall'attacker
Vulnerability	Condizioni realizzabili dall'attackee software
Capability	Operazione con cui l'attacker realizza l'anti-requirement

Classificazione DDTA

documentation_plus_goal_object_domain_model_required_or_created

La fonte ammette input iniziali documentali, ma non analizza documenti eterogenei direttamente. La compatibilita documentation-first dipende dalla costruzione governata delle viste goal, agent, object, operation e domain property.

SRC-0004 - Assurance, automazione e contromisure

Derivazione e automazione

Meccanismo	Portata
HOW/WHY	Elicitazione informale guidata
Regression through domain properties	Precondizioni di attacco nel dominio
Regression through primal goals	Sfruttamento di feature software
Refinement / obstruction patterns	Regole riusabili e prova locale
Bounded SAT	Generazione di scenari da anti-goal formalizzati

L'automazione e downstream: richiede un modello formale sufficientemente completo. Sensitive object, attacker, motive, domain property, severity e scelta della contromisura restano responsabilita umane.

Operatori di contromisura

Famiglia	Operatori
Obstacle resolution	Goal substitution, agent substitution, weakening, restoration
Anti-goal handling	Mitigation, prevention
Security-specific	Protect vulnerability, defuse threat, avoid vulnerability
Selection	Severity, likelihood e altri non-functional goal

Assurance e limiti

Aspetto	Valutazione
Punto di partenza	Goal negation esplicita
Prova locale	Possibile su refinement specifici
Scenario generation	Possibile dopo formalizzazione
Completezza globale	Non dimostrata
Termination	Problema esplicitamente aperto
Anti-model validation	Quattro case study
Document provenance	Assente

Catena DDTA candidata

document assertion -> Base Analysis fact -> primal-model view -> anti-goal derivation -> candidate vulnerability/anti-requirement -> human review -> accepted finding -> countermeasure alternative -> security requirement or environmental expectation

SRC-0004 - Confronto e implicazioni DDTA

Confronto con SRC-0003

Dimensione	SRC-0003	SRC-0004
Centro	Scenario	Goal e attacker intent
Input minimo	Use case	Goal/object/agent/domain model
Formalita	Template informali	Logica, regression e pattern opzionali
Threat output	Misuse scenario	AND/OR anti-goal graph
Foglie	Misuse / mitigation	Anti-requirement / vulnerability
Assurance	Review e trace link	Prova locale di derivazione
Stopping	Assente	Aperto esplicitamente

Controlli richiesti a DDTA

Controllo	Requisito
View contract	Goal, agent, object, operation, domain property
Provenance	Documento -> Base Analysis -> primal-model assertion
Derivation	Rule, premises, proof status e alternative
Uncertainty	Extracted, supplied, inferred
Typed findings	Anti-requirement distinto da vulnerability
Responsibility	Software requirement distinto da expectation
Review	Candidate -> proposed -> accepted/rejected
Completion	Coverage, incompleteness e stopping globali
Evolution	Rieseguire derivazioni impattate dai cambiamenti

Cosa non possiamo sostenere

- Che il metodo analizzi direttamente documentazione arbitraria.
- Che formalizzazione e SAT eliminino il giudizio dell'analista.
- Che una refinement localmente completa copra tutte le minacce.
- Che il ciclo termini sempre.
- Che quattro case study dimostrino superiorita o scalabilita.

Prossima lettura

Haley et al.: security requirements e satisfaction arguments. La prossima fonte dovra verificare come si dimostra che un insieme di requisiti soddisfa una definizione di sicurezza e quale evidenza e responsabilita richiede.